The Australian Cardiovascular disease Data Commons (ACDC)

Data Breach Policy

Table of Contents

1. Scope 2
2. Background and definitions 2
   What is a data breach? 2
   What is considered serious harm? 2
   How do breaches occur? 3
3. Data breach response process 3
4. Data Breach Response 6
Associated Documents 6
   Acknowledgments 6
References 7
Revision History 7
Appendix 1: Data breach response plan quick checklist 8
Appendix 2: Template for communication to individuals whose data is affected 10

1. Scope

The *Privacy Act 1988* (Cth) is the main privacy law in Australia. In 2017, there was an amendment to this Act, the *Privacy Amendment (Notifiable Data Breaches) Act 2017.* Under this Act any organisation or agency the *Privacy Act 1988* covers must notify affected individuals and the Office of the Australian Information Commissioner when a data breach is likely to result in serious harm to an individual whose personal information is involved.

This data breach policy defines what is considered a data breach and sets out procedures to follow if: ACDC experiences or suspects a data breach, or an ACDC data holder experiences a breach affecting ACDC data. It presents a data privacy framework nominating roles and responsibilities for the management of a data breach, depending on which ACDC computing resources or external data holders were affe cted.

The aim of this policy and the response process it describes is to mitigate potential harm to affected individuals, by facilitating an efficient and comprehensive response to a suspected or confirmed data breach.

This policy covers all data created, managed, and shared by ACDC irrespective of the purpose and use of the collected data.

2. Background and definitions

What is a data breach?

The Office of the Australian Information Commissioner (OAIC)[1] defines a data breach occurring when "personal information that an entity holds is subject to unauthorised access or disclosure, or is lost."

The following are examples of data breaches:

- Loss or theft of a physical device (such as a laptop or mobile storage device) or paper records containing personal, identifiable or re-identifiable information;
- Disposal of digital hardware data storage without prior permanent deletion of all content on the device;
- Inadvertent disclosure of personal or identifiable information due to human error, such as an email with identified or re-identifiable data sent to the wrong recipient;
- Unauthorised access to personal, identifiable or re-identifiable data;
- A database being illegally accessed by any individual or group outside of ACDC;
- An ACDC data holder accessing data beyond their approved scope of work.

What is considered serious harm?

'Serious harm' is not defined in the Privacy Act. In the context of a data breach, serious harm to an individual may include serious physical, psychological, emotional, financial, or reputational harm.

In the case of a data breach, serious harm can impact upon the individual whose personal information is involved in the data breach. Serious harm to the individual might manifest itself in various forms: it may affect the physical or mental and emotional well-being of an affected individual; it could also, for example, result in financial loss, damage to their reputation or identity theft.
Serious harm could also impact upon the institution(s) holding and/or handling the data involved in the data breach by way of reputational damage. This can however be mitigated by the institution(s) demonstrating

accountability, effectiveness and transparency in their data breach response and in the handling of the personal information in their care.

How do breaches occur?

Data breaches can have many origins, not all of which are malicious. A data breach can:

- Occur when information is mishandled by staff;
- Be due to an organisation not having appropriate data handling and management policies and procedures in place;
- Be caused by human error, sharing information to an incorrect recipient;
- Be of malicious intent, presenting as an information technology or service attack.

These are only some examples of how a data breach can originate: this list is by no means complete or exhaustive. There are many other ways data can be lost, accessed and/or disclosed without authorisation.

3. Data breach response process

Should you suspect or are made aware of a data breach, the ACDC user must immediately notify: security@biocommons.org.au irrespective of the severity of the breach. This email box is monitored and will alert the ACDC Platform Governance Committee.

In this email, you should include all information you have regarding the data breach, including but not limited to:

- The type of data that is affected;
- The individual or cohort of individuals affected;
- The time the breach first occurred;
- The type of breach (see above);
- Your contact details.

The ACDC Platform Governance Committee will then contact you for further details, and/or to advise you of the progress or resolution of the breach.

Each data breach will be considered on a case-by-case basis. Not all steps described in the framework below may be required, depending on the severity of the data breach. Evaluation and management of the breach is the responsibility of the ACDC Platform Governance Committee, who will determine the actions required.

Upon notification, the ACDC Platform Governance Committee will follow the four key points of the strategy as described here, summarised in Figure 1 and listed in the checklist in Appendix 1:

1) ***Contain*** *the breach (immediately)*
    a. This can be by limiting, or entirely removing, access to the affected data system; or
    b. By physically switching off the hardware supporting the affected system;
    c. Making sure to preserve evidence that may be valuable in assessing the breach and risks associated with it.

To help the core team identify the most suitable strategy to contain the breach, the core team must address the following questions:

- How did the data breach occur?
- Is the data affected by the breach still being shared or disclosed without authorisation? Or is it still lost?
- Who currently has access to the affected data?
- What can be done to secure the information, restrict access to it and stop unauthorised access and potential harm to the affected individual(s)?

2) ***Assess*** *the risks associated with the breach (within the first 48 hours of the breach being known/discovered)*
   a. Inform the data custodian of the potential breach
   b. Conduct an internal investigation to collect information about the breach, including:
      i. Date, time, duration and location of the breach;
      ii. Type of personal information involved in the breach;
      iii. Who discovered the breach and how;
      iv. A list of all affected individuals and the risk of resulting serious harm to them.
   c. Establish the cause, circumstances and extent of the breach.
   d. Establish which parties have gained unauthorised access to the personal information.
   e. Assess risks and priorities based on the collected facts and information.
   f. Keep a record of all steps actioned, as well as the reasoning behind those steps, since the discovery of the breach.

3) ***Notify*** *(within 7 days of the breach being known/discovered)*
   To decide who is to be notified and how, the ACDC Platform Governance Committee should consider the following:
   - The risk of harm to the individual(s) whose data is being breached;
   - The risk to the wider community;
   - If notification to the affected individual(s) would create more unnecessary harm than benefits, such as stress and anxiety;
   - The number of individuals affected;
   - If the data breach indicates a systematic problem with respect to data handling;
   - The risk to the reputation of the ACDC data custodians and partnering entities.

   The core team must consider notifying the following parties:
   a. The affected individual: The ACDC Platform Governance Committee is to determine whether notification is required and identify the notification list, depending on the severity of the breach; the type of personal data affected; the risk of serious harm to the individual and the wider community; and the practicality of contacting the individual(s). If notification is required, it will fall into one of the following three categories in order to be able to take steps to reduce their own risk of harm:
      i. Only those individuals at risk of serious harm, by phone or email;
      ii. All individuals involved in ACDC, including data custodians, staff and partner entities, by either phone or email as appropriate
      iii. Requiring public notification (if i. or ii. are not practicable) via an email newsletter and/or announcement on the ACDC website.

b. The relevant authorities, if required. This includes law enforcement agencies and the Office of the Australian Information Commissioner (OAIC) in the case of a notifiable breach. For a breach to qualify for the Notifiable Data Breach scheme, it must involve jointly held information and/or serious harm to individuals is likely to occur (see further information here). The phrase "likely to occur" means the risk of serious harm to an individual is more probable than not (rather than possible).

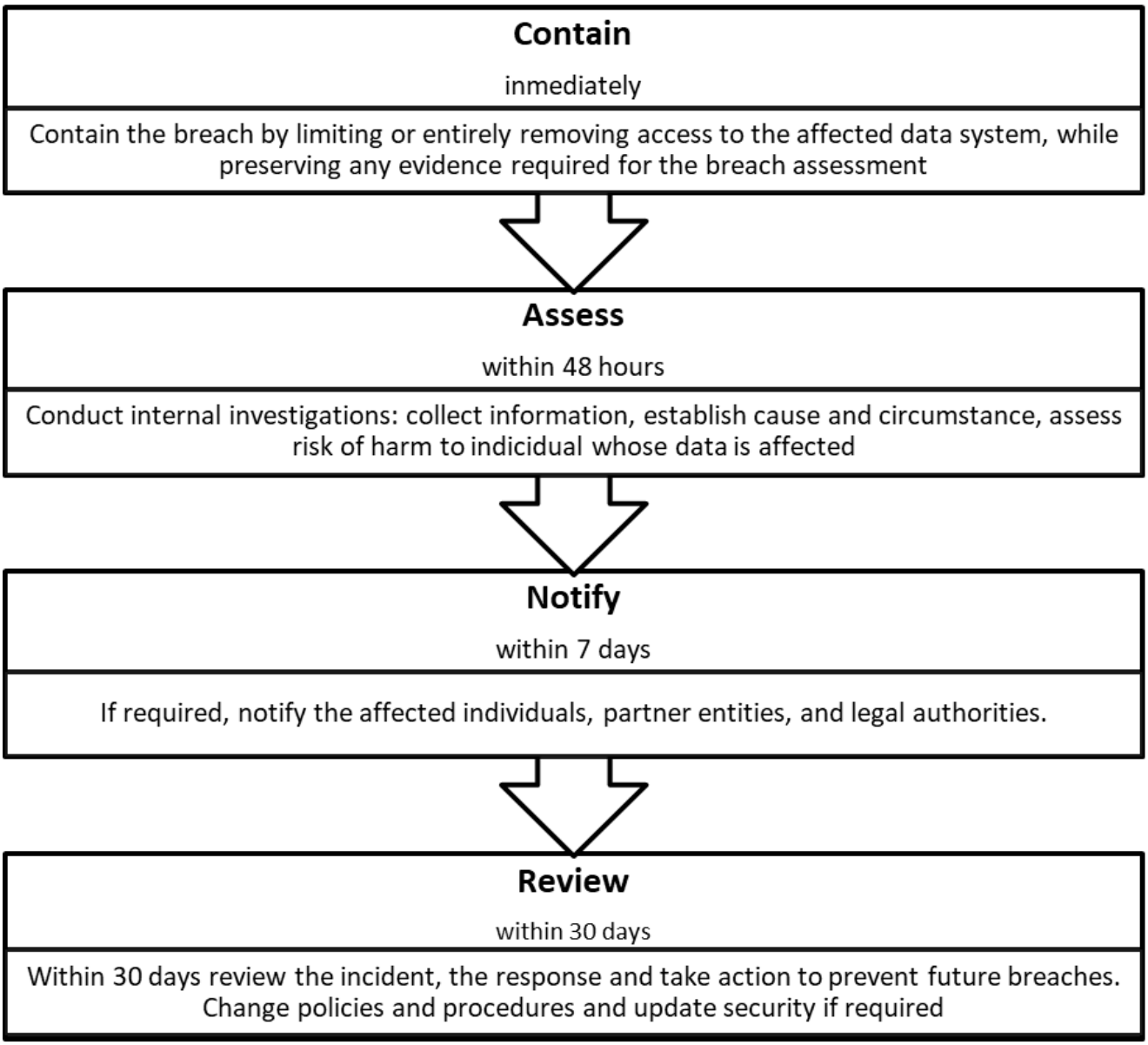
c. For more details, please read Notifiable Data Breaches Scheme[2]. The report must be communicated by the ACDC Platform Governance Committee to the OAIC either by email to enquiries@oaic.gov.au, by phone: 1300 363 992 or via the web form[3]. The notification and reporting to the OAIC must be performed within 30 days of breach discovery.

4) ***Review*** *the incident, the response and take action to prevent future breaches (within 30 days of breach discovery)*
   a. Implement strategies to address any weaknesses identified during the assessment process;
   b. Update security and the data breach response if necessary;
   c. Change policy and procedures if required.

Within 30 days of the data breach being discovered, a meeting with all major stakeholders and partners must be held and minuted, to review and improve data management processes and policies.
In case of a severe data breach, steps one to three may need to be performed simultaneously or in rapid succession, in order to efficiently mitigate the potential harm to the individual(s) whose data is affected.
Irrespective of the severity of the data breach, a copy of the notification email, as well as a record of all steps undertaken and their justification, are to be stored in an internal governance folder for traceability and reference.

Keeping records of a data breach will enable a full assessment of weaknesses in the data access and storage systems as well as providing accountability and transparency for participating individuals and stakeholders.
To ensure this data breach policy remains adequate and fit-for-purpose, it will be reviewed on an annual basis or at the launch of any new major data tool.

Figure 1: Data Breach Response Process



4. Data Breach Response

The ACDC Platform Governance Committee will follow the relevant steps to contain, stop and, where possible, revert the data breach as specified in this policy.

Associated Documents

- ACDC Data Sharing Policy
- Data Sharing Agreement Template

Acknowledgments

This policy has been adapted from the Australian Genomics Data Breach Policy V1.3 dated 10/06/2022.

References

1. Data breach preparation and response: A guide to managing data breaches in accordance with the Privacy Act 1988 (Cth): https://www.oaic.gov.au/privacy/guidance-and-advice/data-breach-preparation-and-response
2. Notifiable Data Breaches Scheme from the Office of the Australian Information Commissioner (OAIC): https://www.oaic.gov.au/privacy-law/privacy-act/notifiable-data-breaches-scheme - overview
3. Notifiable Data Breaches Scheme reporting online form: https://forms.business.gov.au/smartforms/landing.htm?formCode=OAIC-NDB

Revision History

Version	Date	Author	Reviewer	Approver	Nature of Change
1.0	19/03/2024	Adapted by Dr Catherine Shang Dr Talia Palacios	ACDC Data Governance Group	ACDC Platform Governance Committee	Initial version
1.1	26/03/2025	N/A	ACDC Platform Governance Working Group	ACDC Project Management Committee	Security email address added to Section 3 and Appendix 1

Appendix 1: Data breach response plan quick checklist

Note: All data users to complete Steps 1 and 2

Step 1: Contain the breach

- ❑ Notify security@biocommons.org.au
- ❑ Limit or entirely remove access to the affected data tool
- ❑ Preserve evidence for breach assessment
- ❑ Determine best strategy to contain the breach by answering following:

Issue	Comment
How did the data breach occur?	
Is the data affected by the breach still being shared or disclosed without authorisation? Or is it still lost?	
Who currently has access to the affected data?	
What can be done to secure the information, restrict access to it and stop unauthorised access and potential harm to the affected individual(s)?	

Step 2: Assess the risk associated with the breach

- ❑ Conduct an internal investigation to collect the following information
- ❑ Date, time, duration and location of the breach
- ❑ Type of personal information accessed during the breach
- ❑ Who discovered the breach and how
- ❑ A list of all affected individuals and the risk of resulting serious harm to them
- ❑ Establish the cause, circumstance and extent of the breach
- ❑ Establish what parties have gained unauthorised access to the personal information
- ❑ Assess risks and priorities from what is known
- ❑ Keep a record of all steps actioned since the discovery of the breach

Note: *Steps 3 and 4 for ACDC use only*

Step 3: Notify

❑ The core team, including the communications team, should decide who needs to be made aware of the breach (individuals affected, partners, external authorities) by answering the following:

Issue	Comment
What is the risk of harm to the individuals whose data is being breached?	
What is the risk to the wider community?	
Would a notification create more unnecessary harm (like stress or anxiety) than benefit?	
What is the number of affected individuals?	
Does the data breach indicate a systematic problem?	
What is the risk to the reputation of the ACDC platform custodian, cohort custodian and partnering entities?	

❑ How are individuals to be notified?
- Via phone or email if practicable
- Via a newsletter or general email to all participants and/or partners and staff.
- Via a public notification by means of an email or announcement on the website.

❑ Example of email or announcement of a data breach in Appendix 2

❑ Notification to outside relevant authorities (Federal Police, OAIC, or other relevant authorities depending on the type and severity of the data breach.)

Step 4: Review the incident

Within 30 days of discovery of the breach, the core team is to organise a meeting with the relevant partners and stakeholders to review the incident, address any weaknesses identified during the assessment and update all necessary policies and documents.

Issue	Comment
Date of review meeting	
Weaknesses to be addressed	
Policies and documents to be updated	

Appendix 2: Template for communication to individuals whose data is affected

Dear (insert name)

- We are writing to let you know that an incident occurred with our computer systems (when) that (may affect you/reassure that it won't affect them and what this means for them)
- (Describe incident in plain language and its impact on the person you are addressing)
- (Describe how we are responding to the incident)
- We apologise sincerely for any (concerns/inconvenience) this may have caused you.
- (Reassure them that everything is being done to ensure it does not recur etc.)
- (Provide options for them to pursue from here/what they might want to do)
- (Provide contact person and details for further queries)

While writing the data breach notification letter, please ensure that you:

- ❑ Take responsibility and apologise sincerely
- ❑ Be clear and express yourself in simple yet factual manner for everyone to understand
- ❑ Explain the possible options for the participants, without instilling fear in them
- ❑ Reassure the participants by explaining what has been done thus far and what actions will be undertaken to prevent a similar incident to occur in the future